

PROJECT REPORT

BARAZ

A Full-Stack E-Commerce Platform – Supabase BaaS Architecture

PREPARED BY	STUDENT ID	COURSE	DATE
Ehsanul Tanjil	223014022	CSE347	31 August 2026

01 Overview

BARAZ is a full-stack e-commerce platform built as a modern, high-performance web application utilizing a **Backend-as-a-Service (BaaS)** architecture powered directly by **Supabase**. It features a complete customer storefront, robust token authentication, persistent server-side cart synchronization, inventory-validated atomic checkout, customer order tracking, and an administrative back office.

Transitioning from a multi-tier Spring Boot architecture to a direct Supabase BaaS eliminated cold-start server delays and hosting overhead. All critical transactional rules, stock deductions, pricing integrity, and security policies are enforced at the database layer using **PostgreSQL Row-Level Security (RLS)**, stored procedures (PL/pgSQL RPCs), and database triggers.

02 Objectives

- **Complete E-Commerce Lifecycle:** Deliver a functional platform covering product discovery, cart synchronization, inventory verification, instant checkout, and admin oversight against live PostgreSQL storage.
- **Direct BaaS Architecture:** Streamline communication directly between the static frontend and Supabase via the JavaScript SDK, removing the need for a dedicated Java/Node API layer.
- **Atomic Business Logic via RPC:** Implement critical order mutations in PostgreSQL stored procedures (`SECURITY DEFINER`) to ensure ACID compliance and prevent client-side price tampering.
- **Robust Data Security & RLS:** Enforce strict Row-Level Security policies so customers can only access their own orders and cart data, while administrators maintain elevated privileges.

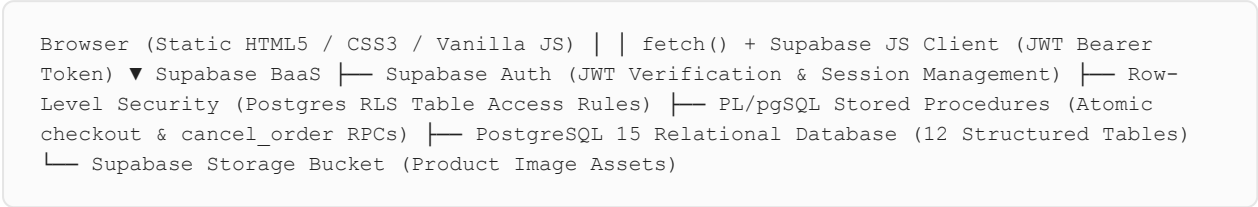
03 Technology Stack

LAYER	TECHNOLOGY	NOTES
Frontend	HTML5 / CSS3 / Vanilla JavaScript	Framework-free, zero build step; high performance and instant page load.
Backend (BaaS)	Supabase Platform	Managed PostgreSQL, Auth, Storage, and serverless Edge RPC endpoints.
Database	PostgreSQL 15 (Supabase)	Relational schema secured with Row-Level Security (RLS) & Triggers.
Business Logic	PL/pgSQL Stored Procedures	Atomic checkout() and cancel_order() executed server-side.
Authentication	Supabase Auth	Email + password authentication with ES256-signed JWT sessions.
File Storage	Supabase Storage	Public CDN hosting for product catalog photography and media assets.
Dev Server	Node.js (server.mjs)	Lightweight local static development server.

Hosting: Frontend is deployed to Vercel/Netlify/GitHub Pages as pure static assets, while database, auth, and logic run on Supabase with zero server maintenance and 100% uptime.

04 System Architecture

The frontend communicates directly with Supabase via the `@supabase/supabase-js` client library using standard JWT bearer authorization. There is no intermediate container or API layer:



Client requests carry JWT tokens verified automatically by Supabase. Access to raw table rows is filtered by PostgreSQL RLS, while complex checkout calculations are handled by server-side RPC functions.

05 Database Design & Security

A relational schema of **12 tables** covers identity, product catalog, cart, orders, and customer engagement:

GROUP	TABLES	DESCRIPTION & SECURITY SCOPE
Identity	profiles	User accounts linked to <code>auth.users</code> ; protected by role-escalation triggers.
Catalog	categories, products, product_images	Publicly readable for active items; write-restricted strictly to ADMIN.
Cart	cart, cart_items	Isolated user shopping carts; RLS strictly enforces <code>auth.uid() = user_id</code> .
Orders	orders, order_items, payments	Customer viewable only; mutations managed via atomic RPC and admin operations.
Engagement	reviews, wishlist, coupons	Customer reviews, persisted saved wishlists, and discount coupon codes.

- **Row-Level Security (RLS):** Enabled across every table. The helper function `is_admin()` prevents policy recursion.
- **Role Escalation Guard:** The `prevent_role_self_escalation()` trigger prevents non-admins from self-promoting to ADMIN.
- **Automated Profile Creation:** The `handle_new_user()` trigger provisions a profile row upon registration.

06 Serverless Stored Procedures (RPC)

Complex, multi-table transactions are executed inside atomic PostgreSQL functions:

FUNCTION	TYPE	ROLE & EXECUTION BEHAVIOR
<code>public.checkout()</code>	PL/pgSQL RPC	Validates user cart, verifies real-time stock, computes true total from database prices, inserts order + items, decrements inventory, creates payment record, and clears cart in a single transaction.
<code>public.cancel_order()</code>	PL/pgSQL RPC	Verifies order status and ownership, sets status to CANCELLED, and automatically returns item quantities back into product inventory.
<code>public.is_admin()</code>	SQL Function	Security definer helper checking if the calling user has ADMIN role.

07 Key Features

- **Role-Based Routing:** Single login page intelligently redirects admins to `admin/dashboard.html` and customers to `account.html`.
- **Route Guards:** Customer pages automatically deflect admin sessions to the back-office, while admin pages strictly enforce `barazRequireAdmin()`.
- **Dynamic Product Catalog:** Instant search, category filters, price range sliders, and multi-criteria sorting.
- **Multi-Tab Product Detail:** Full product showcase with dynamic photo gallery, stock tracking, and quantity stepper.
- **Atomic ACID Checkout:** Server-side stock deduction, calculated shipping rates (free over ₹15,000), and multi-payment simulation.
- **Customer Order Tracking:** Order status step tracker (Confirmed → Processing → Shipped → Delivered) with receipt modals.
- **Full Administrative Back-Office:** Metrics cards, sales charts, product CRUD operations, order status updates, and session logout.
- **Zero Cold-Start Delay:** Instant responses with no container spinning or idle timeout latency.

08 Deployment

- **Frontend:** Hosted as high-performance static files on **Vercel** / **Netlify** / **GitHub Pages**.
- **Backend & Database:** Hosted on **Supabase** with edge-accelerated REST and RPC APIs.

Eliminating standalone virtual machines or containers removed all free-tier sleep cycles. The platform responds instantly to all client interactions.

09 Known Limitations & Future Work

- **Payment Processing:** Card and mobile payments are processed in instant simulation mode; COD orders default to PENDING.
- **Coupons & Reviews:** Database tables are fully migrated and ready; frontend coupon redemption and review submission UI can be wired directly to Supabase.

10 Conclusion

BARAZ successfully demonstrates the power, speed, and simplicity of modern **Serverless BaaS architecture**. By leveraging Supabase for database-level security, authentication, and atomic stored procedures, the application provides an enterprise-ready e-commerce experience with lightning-fast load times, zero server maintenance, and guaranteed transactional integrity.

